DIRECTIVE SUR LA RÉSILIENCE DE LA SÉCURITÉ DE L'INFORMATION

Avis de confidentialité

Ce document contient des informations qui sont destinées à l'usage exclusif de iA Groupe financier.

Sous réserve d'une approbation d'un représentant dûment autorisé de iA Groupe financier, toute reproduction de ce document, ou sa distribution à l'extérieur de son groupe autorisé d'utilisateurs est interdite.

Table des matières

1. Introduction 3
   1.1. Portée 3
   1.2. Contexte 3
   1.3. Définitions 3
2. Exigences de la directive 4
   2.1. Exigences relatives à la gestion des incidents de sécurité 4
   2.2. Exigences relatives à la planification de la relève 5
3. Écarts et exceptions 5

Directive sur la résilience de la sécurité de l'information	
Propriétaire	Chef de la sécurité de l'information (CISO)
Portée	Groupe
Objectif de la norme	Établir les exigences en matière de résilience de la sécurité de l'information dans l'environnement technologique de iA Groupe financier.
Date de révision	s.o.
Autorité d'approbation	Comité directeur sur la sécurité de l'information
Date d'approbation	7 Avril 2022
Date d'entrée en vigueur	7 Avril 2022
Fréquence de revue	Tous les trois (3) ans ou à la suite de changements majeurs
Prochaine révision	2024-12

1. Introduction

1.1. Portée

La *Directive sur la résilience de la sécurité de l'information* s'applique à iA Groupe financier, à ses employés, à ses fournisseurs de services et à ses sous-traitants, consultants et toute personne dont le travail est sous la responsabilité de la direction de la Société, sur laquelle la Société exerce un contrôle direct et qui utilise les actifs de iA Groupe financier.

1.2. Contexte

La Société doit préparer et suivre des plans orientés vers l'activité qui évaluent en permanence les risques pour ses opérations et doit mettre en place l'infrastructure et préparer le personnel et les processus nécessaires pour minimiser l'impact de ces risques.

1.3. Définitions

Une « équipe de réponse aux incidents de cybersécurité » est une capacité mise en place dans le but d'aider à répondre aux incidents liés à la cybersécurité.

« iA Groupe financier » ou « la Société » désigne iA Société financière inc. et ses filiales directes et indirectes, exerçant leurs activités sous le nom iA Groupe financier.

Un « plan de continuité des activités » consiste en des procédures documentées qui guident une organisation pour répondre, récupérer, reprendre et rétablir les activités à un niveau de fonctionnement prédéfini à la suite d'une perturbation.

Un « plan de relève technologique » est un plan élaboré conjointement avec le plan de continuité des activités qui détaille les stratégies de relève technologique pour restaurer le matériel, les applications et les données à temps pour atteindre les objectifs de temps de reprise des activités.

Un « plan de réponse aux incidents » consiste en la documentation d'un ensemble prédéterminé d'instructions ou de procédures pour détecter les incidents, y répondre et en limiter les conséquences.

2. Exigences de la directive

2.1. Exigences relatives à la gestion des incidents de sécurité

La Société doit disposer d'un plan de réponse aux incidents (plan de RI) pour comprendre, gérer et récupérer avec succès les incidents de sécurité des informations lorsqu'ils se produisent. La Société doit évaluer l'impact des incidents afin de les classer par ordre de priorité. Les exigences nécessaires pour garantir que la Société est correctement préparée à identifier, signaler et répondre aux incidents de sécurité de l'information sont énumérées ci-dessous :

a. Créer une équipe de réponse aux incidents de cybersécurité (ÉRIC), avec des responsabilités définies pour chacun de ses membres, afin de doter la Société de la capacité appropriée pour se préparer, détecter et répondre aux incidents de sécurité de l'information.
b. S'assurer que les membres de l'ÉRIC connaissent l'architecture et les composants de l'environnement technologique de la Société et qu'ils sont équipés des outils et des ressources nécessaires pour répondre aux incidents.
c. Fournir une formation pour s'assurer que tous les employés et contractants sont conscients et éduqués sur les exigences de divulgation des incidents de sécurité de l'information, ainsi que sur les points de contact pour le soutien à la réponse aux incidents.
d. Identifier toutes les parties internes et externes impliquées dans la gestion des incidents et s'assurer de leur compréhension de leurs rôles respectifs lors d'un incident.
e. Documenter et maintenir un plan de RI écrit qui décrit explicitement tous les éléments pertinents de la réponse aux incidents.
f. Tester et mettre à jour le plan de RI à intervalles réguliers.
g. Déclarer, documenter et classer chaque incident subi par la Société selon les critères définis dans le plan de RI.
h. Définir des voies de signalement et d'escalade qui respectent les directives de gestion de crise et de communication de la Société, les procédures de protection des renseignements personnels et les autres exigences de conformité.
i. Établir des stratégies de confinement distinctes pour chaque type d'incident majeur afin de faciliter la prise de décision et d'assurer la préservation des preuves.
j. Réaliser et documenter une analyse post-mortem de la réponse à l'incident après un incident majeur et périodiquement après des incidents non majeurs.

2.2. Exigences relatives à la planification de la relève

La Société est confrontée à un nombre croissant de risques qui peuvent avoir un impact sur la continuité des opérations, notamment les catastrophes naturelles, les pannes d'équipement, les cyberattaques et les erreurs opérationnelles. Ainsi, la Société doit améliorer son état de préparation pour répondre et se rétablir rapidement en cas d'interruption de service. Les exigences nécessaires à l'établissement de plans de relève technologique (PRT) tactiques soutenant le plan de continuité des activités afin de contribuer à minimiser les impacts sur les opérations, les revenus et l'image de marque de la Société en cas de perturbation de ses activités sont énumérées ci-dessous :

a. Établir un comité d'opérations de relève (COR) avec des responsabilités définies pour chacun de ses membres, qui est responsable des plans tactiques de reprise des processus opérationnels essentiels pendant une perturbation.
b. Documenter et tenir à jour un PRT pour chaque actif technologique de la Société qui soutient les processus essentiels identifiés dans la pratique de gestion de la continuité des activités et s'assurer que les processus et procédures associés sont en place pour soutenir le PRT.
c. Assurer une synchronisation constante entre le COR et les autres groupes de la Société qui pourraient devoir participer à la relève technologique afin d'accroître l'efficacité du PRT et de minimiser le temps de transfert des connaissances pendant une crise.
d. S'assurer que les PRT sont testés et mis à jour à intervalles réguliers pour refléter les changements apportés aux opérations.
e. Sélectionner et maintenir des sites alternatifs de reprise après sinistre qui fournissent une capacité de sauvegarde adaptée aux risques, à la criticité et à la nature des processus opérationnels impliqués.
f. Sauvegarder régulièrement les systèmes d'information d'une manière adaptée à la criticité des processus opérationnels.
g. Coordonner la réponse avec l'ÉRIC et d'autres équipes de réponse aux incidents pour la détection, l'analyse et la récupération.
h. Suivre les directives de gestion de crise et de communication de la Société pour toute communication interne ou externe.
i. Réaliser et documenter une analyse post-mortem des activités de récupération après un sinistre, et agir en fonction des leçons apprises en mettant à jour le PRT.
j. Revoir régulièrement chaque PRT afin d'en assurer l'efficacité et d'y intégrer les leçons apprises.

3. Écarts et exceptions

Dans les cas où cette directive n'est pas respectée, une demande de dérogation doit être remplie en suivant le processus de dérogation au cadre normatif de sécurité de l'information.

Veuillez contacter l'équipe de sécurité de l'information < *DemandesSecuriteSI@ia.ca* > pour obtenir plus d'informations sur ce processus ou sur la directive, le cas échéant.